

Document Title:	CyberTech A.Ş. Erişim Kontrol Politikası		
Document ID:	CT-POL-001	Version:	01
Status:			
Publish Date:			

CYBERTECH A.Ş.

Bilgi Güvenliği Politikası

Erişim Kontrol Politikası

Belge No	CT-POL-001
Sürüm	1.0
Yürürlük Tarihi	Nisan 2026
Politika Sahibi	Bilgi Güvenliği Ekibi
Onaylayan	CISO / Genel Müdür
Gizlilik	DAHİLİ

1. Amaç

Bu politika, CyberTech A.Ş.'nin bilgi varlıklarına, sistemlerine, ağlarına ve verilerine erişimin yetkilendirilmesi, denetlenmesi ve izlenmesi için gereken kuralları ve prosedürleri tanımlar. Temel amaç; yalnızca yetkili kullanıcıların iş gereksinimleri doğrultusunda gereken minimum erişim düzeyine sahip olmasını sağlamak ve yetkisiz erişim riskini en aza indirmektir.

2. Kapsam

Bu politika aşağıdakileri kapsar:

- Tüm CyberTech A.Ş. çalışanları, yöneticileri ve iş ortakları
- Şirkete ait veya şirket tarafından yönetilen tüm bilgi sistemleri, uygulamalar ve ağ bileşenleri
- Uzaktan çalışma ortamları dahil tüm erişim kanalları
- Üçüncü taraf hizmet sağlayıcılar ve danışmanlar

Document Title:	CyberTech A.Ş. Erişim Kontrol Politikası		
Document ID:	CT-POL-001	Version:	01
Status:			
Publish Date:			

3. Yasal ve Regülatif Dayanak

Düzenleme	İlgili Yükümlülük
KVKK (6698)	Kişisel verilere erişimin sınırlandırılması ve denetlenmesi zorunluluğu
GDPR	Madde 5: Veri minimizasyonu: yalnızca ihtiyaç duyulan veriye erişim
ISO/IEC 27001	A.9 Erişim Kontrolü: Kullanıcı erişim yönetimi ve erişim kontrol politikası
PCI-DSS	Gereksinim 7: Kart sahibi verilerine erişimi iş gereğiyle sınırlandır
BDDK	Bilgi sistemleri yönetiminde asgari güvenlik gereksinimleri

4. Tanımlar

Tanım	Açıklama
En Az Yetki	Kullanıcıların yalnızca görevleri için gereken minimum düzeyde erişime sahip olması ilkesi
RBAC	Role-Based Access Control / Rol Tabanlı Erişim Kontrolü
MFA	Multi-Factor Authentication / Çok Faktörlü Kimlik Doğrulama
Ayrıcalıklı Hesap	Yönetici veya sistem düzeyinde yüksek izinlere sahip kullanıcı hesabı
Görev Ayrılığı	Kritik işlemlerin tek bir kişide toplanmasını önlemek için sorumlulukların bölünmesi

Document Title:	CyberTech A.Ş. Erişim Kontrol Politikası		
Document ID:	CT-POL-001	Version:	01
Status:			
Publish Date:			

5. Erişim Kontrol İlkeleri

5.1 En Az Yetki İlkesi

Her kullanıcı ve sistem bileşeni, iş fonksiyonlarını yerine getirmek için gereken minimum erişim haklarına sahip olacaktır. Varsayılan durum 'erişim yok' şeklindedir; erişim iş gerekçesiyle talep edilmeli ve onaylanmalıdır.

5.2 Rol Tabanlı Erişim Kontrolü (RBAC)

Erişim hakları bireyler yerine iş rolleri aracılığıyla yönetilir. Tanımlanan roller:

Rol	Erişim Kapsamı	Örnek Sistemler	MFA Zorunlu
Genel Müdür / CISO	Tüm sistemlere okuma; kritik sistemlere yazma	Tüm sistemler	EVET
IT Yöneticisi	Altyapı tam erişim; uygulama kısıtlı	AD, Sunucular, Ağ	EVET
SOC Analisti	SIEM okuma; log analizi; kısıtlı sunucu	Wazuh, Log sunucuları	EVET
Finans Kullanıcısı	Finansal uygulamalar; iş veritabanı	ERP, muhasebe sistemi	EVET
Son Kullanıcı	E-posta, ofis uygulamaları, dahili portal	O365, intranet	ÖNERİLİR
Üçüncü Taraf	Yalnızca sözleşmeyle tanımlanan sistemler	Belirlenmiş sistemler	ZORUNLU

5.3 Görev Ayrılığı

Aynı kişi hem bir işlemi başlatamaz hem de onaylayamaz. Finansal işlemler, sistem değişiklikleri ve erişim talepleri için en az iki farklı yetkili onayı gereklidir.

Document Title:	CyberTech A.Ş. Erişim Kontrol Politikası		
Document ID:	CT-POL-001	Version:	01
Status:			
Publish Date:			

5.4 Çok Faktörlü Kimlik Doğrulama (MFA)

Aşağıdaki sistemler ve senaryolar için MFA zorunludur:

- Active Directory ayrıcalıklı hesap girişleri
- VPN ve uzaktan erişim bağlantıları
- SIEM platformu (Wazuh) yönetim arayüzü
- Finansal işlem sistemleri
- Tüm bulut hizmet hesapları
- Üçüncü taraf erişimleri

6. Erişim Yönetimi Prosedürleri

6.1 Erişim Talebi

Yeni erişim talepleri aşağıdaki süreç ile işlenir:

- Kullanıcı, İK veya yöneticisi aracılığıyla yazılı erişim formu doldurur
- Bölüm yöneticisi iş gerekçesini onaylar
- IT Güvenlik ekibi talebi 'en az yetki' ilkesi çerçevesinde değerlendirir
- CISO onayı (kritik sistemler için)
- Erişim hesabı oluşturulur ve kullanıcıya güvenli kanal üzerinden iletilir
- Erişim Active Directory / IAM sistemine kayıt altına alınır

6.2 Erişim İnceleme ve Gözden Geçirme

- Tüm kullanıcı erişim hakları 3 ayda bir gözden geçirilir
- Ayrıcalıklı hesaplar aylık olarak incelenir
- Proje bazlı erişimler proje sonunda otomatik iptal edilir
- Rol değişikliğinde mevcut erişim hakları 5 iş günü içinde güncellenir

Document Title:	CyberTech A.Ş. Erişim Kontrol Politikası		
Document ID:	CT-POL-001	Version:	01
Status:			
Publish Date:			

6.3 Erişim İptali

Aşağıdaki durumlarda erişim derhal iptal edilir:

- İş akdinin sona ermesi (işten çıkarma/istifa): aynı iş günü içinde
- Güvenlik ihlali şüphesi: derhal, olay müdahalesi süreciyle birlikte
- Uzun süreli izin (30 günden fazla): hesap askıya alınır
- Görev değişikliği: eski rol erişimi 5 iş günü içinde kaldırılır

7. Ayrıcalıklı Hesap Yönetimi

Yönetici ve servis hesapları standart kullanıcı hesaplarından ayrı tutulur. Ayrıcalıklı hesaplar için geçerli kurallar:

- Yöneticiler günlük işler için standart hesap, yönetsel işler için ayrı yönetici hesabı kullanır
- Servis hesaplarının şifreleri en az 16 karakter olmalı ve 90 günde bir değiştirilmelidir
- Yönetici hesap oturumları tam olarak loglanır
- Paylaşımlı yönetici hesapları kullanılmaz; her yöneticinin bireysel hesabı olmalıdır
- Varsayılan yönetici hesapları (Administrator, root) devre dışı bırakılır

8. Uzaktan / Remote Erişim

- Tüm uzaktan erişimler onaylı VPN üzerinden gerçekleştirilmelidir
- VPN bağlantısı MFA ile korunmalıdır
- Kişisel cihazlardan erişim için MDM (Mobile Device Management) kaydı zorunludur
- Üçüncü taraf uzaktan erişimi yalnızca yetkili pencere boyunca ve izleme altında yapılabilir
- Uzaktan erişim oturumları otomatik olarak 30 dakika hareketsizlik sonrasında sonlandırılır

Document Title:	CyberTech A.Ş. Erişim Kontrol Politikası		
Document ID:	CT-POL-001	Version:	01
Status:			
Publish Date:			

9. İzleme ve Denetim / Monitoring and Audit

- Tüm erişim olayları Wazuh SIEM üzerinde merkezi olarak loglanır
- Başarısız giriş denemeleri gerçek zamanlı uyarı üretir
- Yüksek ayrıcalıklı hesap aktiviteleri 7/24 izlenir
- Erişim logları minimum 1 yıl süreyle saklanır (KVKK ve BDDK gereği)
- Yıllık erişim denetimi gerçekleştirilir ve bulgular raporlanır

10. İhlal Yaptırımları

Bu politikayı ihlal eden çalışanlar disiplin prosedürüne tabi tutulur. İhlal ciddiyetine göre uyarıdan iş akdinin feshine kadar yaptırım uygulanabilir. Yasal ihlaller yetkili mercilere bildirilir.

11. Politika Revizyonları

Bu politika aşağıdaki takvimde gözden geçirilir:

Gözden Geçirme Sıklığı	Yıllık veya önemli değişikliklerde
Sorumlu	Bilgi Güvenliği Ekibi (CISO koordinasyonu)
Son Revizyon	Nisan 2026
Sonraki Revizyon	Nisan 2027